Project Name: SecPurityAI

Project Type: AI-Driven Cybersecurity & Research Platform

Proposed By: Praharsh Pulla

Table of Contents

1.Overview *6*

1.1 Introduction 6

1.2 Purpose 6

1.3 Key Differentiators 6

1.4 Intended Outcomes 7

2. Background & Motivation – Detailed Version *7*

2.1 The Evolving Cybersecurity Landscape 7

2.2 Problems with Current Solutions 7

2.3 Why SecPurityAI? 8

2.4 Motivation for Long-Term Impact 8

3. Detailed Objectives & Scope *8*

3.1 Core objectives 8

3.2 Research-oriented objectives 9

3.3 Scope 9

3.4 Out-of-Scope 9

4. System Architecture *10*

4.1 Control Plane 10

4.2 Observability Plane 11

4.3 Data Plane 11

4.4 Core Data Stores 12

4.5 AI Core 12

4.5.1 Multi-Layer AI Pipeline 12

4.5.2 LLM Reasoning Engine 13

4.5.3 GNN Anomaly Engine 13

4.6 Agents & Actions 13

4.7 Feedback • Isolation • Federation 13

4.8 Cross-Cutting Capabilities 14

4.9 Data Contracts & Key APIs 14

4.10 SLIs/SLOs, Failure Modes & Safeguards 15

How components talk (quick flow recap) 15

5 Data Flow Diagram Description *15*

5.1 Data Entry and Ingestion 15

5.2 Storage and Core Processing 16

5.3 AI Processing and Analysis 16

5.4 Decision and Action Layer 16
5.5 Governance and Feedback 17
5.6 Learning and Adaptation 17
5.7 Observability and Audit Trail 17
6 Technology Stack & Tools 18
6.1 Programming Languages & Runtime 18
6.2 Data Plane & Storage 18
Event Ingestion & Streaming 18
Hot Search / SIEM 18
Data Lake (durable) 18
Vector Database (RAG) 18
Graph Store / Knowledge Graph 18
Metadata & Provenance 18
6.3 AI/ML Core 19
Model Serving & Orchestration 19
LLMs 19
Embeddings 19
RAG Pipeline 19
GNN (Graph Neural Networks) 19
Classic ML & Explainability 19
Causal Inference 19
RL / Agent Simulation (optional) 19
6.4 Control Plane, Safety & Compliance 20
Policy & Governance 20
AI Firewall 20
Identity & Access 20
Compliance Tooling 20
6.5 Simulation, Deception & Isolation 20
Red/Blue Battle Mode 20
Deception/Honeypots 20
Isolation & TEEs 20
6.6 Observability, Audit & Evaluations 20
Telemetry 20
Audit 21
Evaluation Harness 21
6.7 Backend APIs & Services 21
API Frameworks 21
Background Work 21
Packaging & Deployment 21
6.8 Frontend / Analyst Experience 21
Web UI 21
Views 21
6.9 MLOps & DataOps 21

6.10 Security Hardening & Secrets....22
6.11 Local Dev vs Production Profiles....22
6.12 Recommended Versions (starting points)....22
7) Governance & Safety Framework....22
7.1 Alignment with Standards....22
7.2 AI Firewall & Policy Enforcement....23
7.3 Audit & Transparency....23
7.4 Human-in-the-Loop Controls....23
7.5 Release Gates & Continuous Validation....23
7.6 Ethical & Safety Considerations....24
7.7 Governance Dashboard (UI/UX)....24
8) Implementation Roadmap & Phases....24
8.1 Phase 0 – Foundations....24
8.2 Phase 1 – RAG Brain & Policy Enforcement....24
8.3 Phase 2 – Red vs Blue MVP....25
8.4 Phase 3 – Graph Intelligence....25
8.5 Phase 4 – Privacy & Federation....25
8.6 Phase 5 – Deception & High Assurance....26
8.7 Phase 6 – Hardening & Research Publication....26
9 Evaluation & Benchmarking Plan — SecPurityAI....26
9.1 Core Evaluation Dimensions....26
9.2 Benchmarking Methodology....27
a) Synthetic & Replay Testing....27
b) Adversarial Evaluation....27
c) Human-AI Interaction Studies....27
d) Comparative Baselines....27
9.3 Continuous Evaluation Pipeline....27
9.4 Research & Publication Value....28
10 Use Cases & Scenarios....28
10.1 Ransomware Outbreak Detection & Response....28
10.2 APT Lateral Movement (Advanced Persistent Threat)....29
10.3 Insider Threat / Data Exfiltration....30
....31
10.4 Threat Intel Fusion....31

..... 32
11 Future Research Directions..... 32
12 References..... 33

1 Overview

1.1 Introduction

SecPurityAI is an AI-driven cybersecurity platform that unifies multi-layer threat detection (rules/IoCs, ML/DL, and LLM reasoning), graph-based analytics for lateral movement, governed red/blue simulations, retrieval-augmented analysis, and privacy/safety controls into a single, auditable system [1]–[5]. It is designed

to be both **operational** (SOC-ready) and **research-grade** (governance, explainability, repeatability) in line with emerging AI risk-management guidance [6], [7].

- **Hybrid AI detection pipeline.** Fast rules/IoCs and classic ML handle known patterns while ambiguous events escalate to LLM reasoning; hybrid approaches are widely reported to improve accuracy and mitigate false alarms compared to single-method IDS designs [1].
- **GNN analytics for lateral movement.** Graph learning captures multi-hop relationships and temporal pivots typical of APTs [2].
- **Governed red/blue simulation.** Built-in adversary emulation (e.g., via MITRE Caldera) enables safe, repeatable testing of detections and responses [3].
- **RAG-enhanced knowledge.** Retrieval-Augmented Generation grounds LLM outputs in current threat intel, improving specificity and provenance [4], [5].
- **Privacy & safety by design.** Controls map to LLM-specific risks (e.g., prompt injection, insecure output handling) per OWASP, and to NIST AI RMF practices for trustworthy AI [6], [7].

1.2 Purpose

SecPurityAI targets a gap where many tools optimize speed of detection but under-invest in **governance, explainability, and safety**. It aims to be simultaneously:

- **Operationally effective:** real-time detection and response for complex, staged attacks.
- **Scientifically robust:** reproducible evaluations, model cards and decision logs to support audits and research.
- **Governance-aligned:** traceable controls consistent with NIST AI RMF (risk identification, measurement, management, and monitoring) [6], and with sector guidance for generative-AI safety profiles [7].

1.3 Key Differentiators

- **Multi-layer reasoning:** layered rules/ML/LLM to reduce false positives and provide richer context than single-layer detectors [1].
- **Integrated simulation & training:** policy-gated red/blue “battle arena” built on adversary-emulation best practices [3].
- **Privacy by design:** supports **federated learning** (collaborative training without centralizing raw data) and **differential privacy** for sensitive signals [8], [9].
- **Continuous learning:** feedback and benchmarking loops to detect drift and re-tune models; nightly safe tests for LLM-specific risks (per OWASP LLM Top-10) [6].

1.4 Intended Outcomes

- A production-ready platform that **detects and explains** advanced threats (including multi-hop lateral movement) with auditable reasoning [2].
- A **research testbed** for AI safety & explainability with documented model/decision cards for accountability [10].
- A **benchmark suite** for hybrid detection and governed AI operations (simulation → detection → response) to help standardize evaluations across environments [3], [6].

2 Background & Motivation – Detailed Version

2.1 The Evolving Cybersecurity Landscape

Cloud, SaaS, and IoT have expanded enterprise attack surfaces while adversaries increasingly automate campaigns and chain multi-stage tactics. Public-sector and industry threat assessments show continued growth in ransomware, availability attacks, and data-theft operations across regions and sectors. [16]

AI-augmented threats. Law-enforcement and government guidance note that criminals now use **generative AI** to scale and personalize phishing, deepfake voice "vishing," and other social-engineering playbooks—reducing the time and skill needed to deceive victims. [11], [17]

Dwell time trends. While some intrusions can remain undetected for extended periods, frontline telemetry shows defenders have shortened attacker **median dwell time** overall; Mandiant's 2024 report records a **global median of ~10 days in 2023** (down from 16 in 2022), even as evasion tactics evolve. [12]

Zero Trust context. Organizations increasingly adopt **Zero Trust Architecture (ZTA)**—"never trust, always verify"—which shifts decisions from static perimeters to continuous context checks (identity, device, behavior). AI systems that reason over context complement ZTA by assessing *why* activity is risky. [13]

Governance & regulation. In the EU, the **AI Act** entered into force on **1 Aug 2024** and introduces obligations (e.g., transparency, technical documentation, and human oversight for high-risk AI) that directly affect security AI used in critical functions. [14], [15]

2.2 Problems with Current Solutions

Single-layer detection bias. Many tools rely on only signatures *or* a single ML model; layered hybrids reduce false alarms and improve coverage.**[1]**

LLM safety gaps. LLM-powered SOC helpers are susceptible to **prompt injection**, **insecure output handling**, and **data poisoning** unless guarded by input/output filters and policy gates.**[6]**

Black-box decisions & trust. Security teams struggle to operationalize AI when alerts lack explanations, provenance, or policy context. NIST's **AI RMF** emphasizes explainability, transparency, and human oversight as prerequisites for *trustworthy* AI in high-risk domains like cyber defense.**[7]**

Static models & drift. Threats, user behavior, and environments change; without feedback loops, evaluation, and retraining triggers, model performance degrades and false-positive/negative rates creep upward. (Motivates SecPurityAI's continuous testing and self-tuning tied to policy.)

2.3 Why SecPurityAI?

Given AI-enabled threats [11], [17], the ZTA shift to contextual decisions [13], faster—but still incomplete—detection improvements [12], and new governance obligations [14], [15], a platform that **combines hybrid detection, policy-gated LLM use, explainability, and continuous red/blue testing** is timely and necessary. (Architecture and controls align to **OWASP LLM Top-10** and **NIST AI RMF**.)**[6]**, **[7]**

2.4 Motivation for Long-Term Impact

- **Operational:** reduce MTTD/MTTR against multi-stage attacks while documenting *why* actions are taken (ZTA-aligned). [13]
- **Research & standards:** provide reproducible evaluations and artifacts that map to **EU AI Act** transparency/oversight expectations in security contexts. [14], [15]
- **Governance by design:** make safe AI the default via policy gating, input/output filtering, and evidence-backed explanations.**[6]**, **[7]**

3 Detailed Objectives & Scope

3.1 Core objectives

- **Threat simulation & testing.** Stand up a governed **red/blue battle arena** where autonomous Red agents emulate adversary behavior and Blue agents/detectors must identify and respond; execute realistic, repeatable post-compromise techniques nightly to validate detections, playbooks, and policies **[3], [18]**.
- **Hybrid AI threat detection.** Ingest logs/telemetry and pass through a layered pipeline: (1) fast **rules/IoCs**, (2) **ML/DNN** anomaly/pattern detectors, (3) **GNN** analytics for multi-hop lateral movement, and (4) **LLM reasoning** grounded with **RAG**; this broadens coverage and reduces false alarms vs. single-method IDS **[1], [2], [4], [5]**.
- **AI governance & safety.** Enforce allow/deny/**permit-with-conditions** via **policy-as-code** on every AI/tool action; add an **AI firewall** with pre-/post-filters to mitigate prompt-injection, insecure output handling, and data-leakage; maintain audit logs and human-approval gates for high-impact remediations; align to **OWASP LLM Top-10** and **NIST AI RMF [19], [6], [7]**.
- **Deep explainability & causal reasoning.** Produce analyst-friendly reports with contributed evidence (events, subgraphs, TI snippets) and **model/decision cards**; map findings to **MITRE ATT&CK** tactics/techniques to clarify *what* happened and *how* **[10], [18]**.
- **Self-adaptive security posture.** Track SLIs (precision/recall, false-positive rate, MTTD/MTTR, calibration); when drift/uncertainty rises, tighten filters, route more cases to human review, or schedule retraining and safety tests; operationalize continuous **measurement/monitoring** for trustworthy AI **[7], [6]**.

3.2 Research-oriented objectives

- **Benchmark AI safety for security LLMs.** Run recurring suites (prompt-injection, insecure output, excessive agency) against assistants/agents; track pass-rates and regressions; publish configs and results **[6], [7]**.
- **Study autonomous agents under governance.** Observe Red/Blue strategy adaptation under strict **policy-as-code** and human-in-the-loop approvals; measure autonomy-vs-safety trade-offs **[19], [3]**.
- **Advance concept-level interpretability.** Evaluate clarity/utility of **model/decision cards** in SOC workflows; pilot concept-based and counterfactual explanations that analysts can validate **[10]**.
- **Standardize evaluation via ATT&CK mapping.** Score detections and responses against **MITRE ATT&CK** and apply public **mapping best practices** across sims, datasets, and real incidents **[18], [20]**.
- **Publish artifacts.** Release sanitized datasets, evaluation harnesses, and policy templates to accelerate research while preserving privacy/compliance **[7]**.

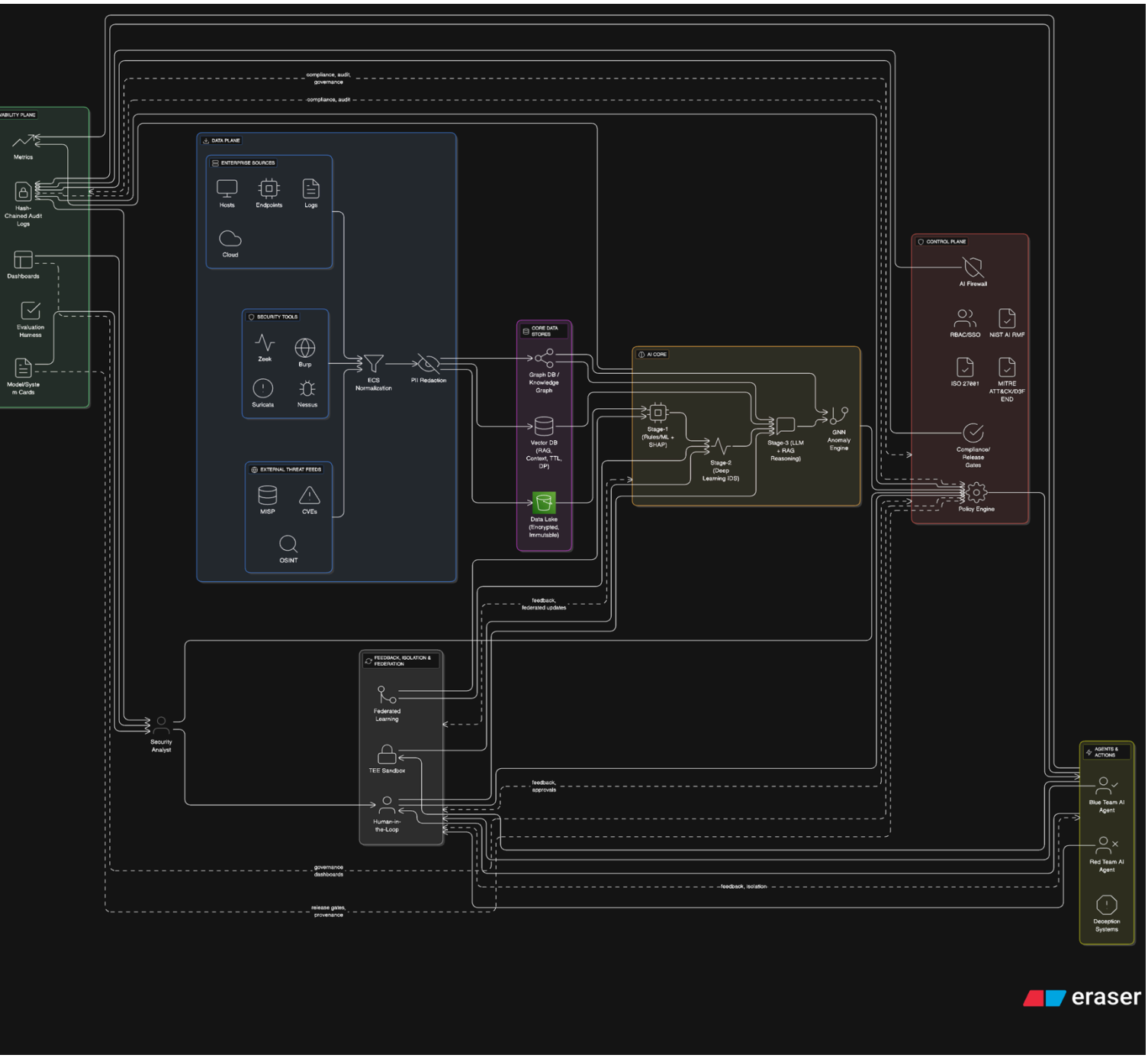
3.3 Scope

- **MVP detection pipeline.** Streaming ingest → rules/IoCs → ML/DNN → LLM reasoning grounded with RAG; include ATT&CK-labeled outputs for analyst context **[1], [2], [4], [5], [18]**.
- **Governance & safety (MVP).** Enforce **policy-as-code** on every AI/tool action; apply **AI firewall** pre/post filters; log policy traces and require human approval for high-impact actions **[19], [6], [7]**.
- **Evaluation harness (MVP).** Nightly adversary-emulation runs to validate detections/playbooks; measure precision/recall, FPR, MTTD/MTTR, and OWASP LLM Top-10 "pass" rates **[3], [6]**.
- **Explainability (MVP).** Generate analyst-readable incident notes plus **model/decision cards** with evidence and rationale tied to ATT&CK **[10], [18]**.
- **V1 detection upgrades.** Add **GNN** analytics for multi-hop patterns; integrate drift monitors and auto-retraining triggers **[2], [7]**.
- **V1 privacy options.** Offer **federated learning** for cross-org model improvement and **differential privacy** where applicable **[8], [9]**.
- **V1 reporting & APIs.** SOC dashboard with policy decisions, ATT&CK coverage views, and exportable reports; programmatic APIs for SIEM/SOAR integration **[18], [19]**.
- **Compliance posture.** Align operational artifacts (decision logs, model/decision cards, evaluations) with **NIST AI RMF** outcomes and **EU AI Act** expectations for transparency and human oversight **[7], [14], [15]**.

3.4 Out-of-Scope

- Offensive testing **outside** the sandboxed lab (no internet-facing live exploitation) **[3]**.
- Full OT/ICS protocol coverage or safety-critical real-time control use cases **(defer to later phases)**.
- Automated production remediation without policy gates and human-in-the-loop approvals **[13], [19]**.
- Regulatory legal advice or formal certification audits (provide evidence, not legal determinations) **[7], [15]**.

4 System Architecture



4.1 Control Plane

Purpose: centralized governance that constrains *every* model, agent, and action.

- **Policy Engine**
  - *What it does:* Evaluates allow/deny rules for tool calls, data access, red-team actions, and blue-team remediations.
  - *How:* Use OPA (Rego) or a YAML DSL.**[19]**Policies reference tenant, user role, model version, action risk, and environment (lab vs prod).
  - *Inputs:* Requested action manifests (JSON), user/tenant context, risk scores, compliance modes.

    - *Outputs:* permit/deny/permit-with-conditions plus rationale; policy evaluation traces for audit.
- **AI Firewall (pre/post filters)**
    - *Pre-filters:* sanitize prompts/contexts, strip secrets, neutralize indirect prompt injection from RAG docs. **[6]**
    - *Post-filters:* scan LLM/GNN outputs for PII, secret exfil, exploit payloads beyond "lab-only," and ensure JSON schema validity. **[6]**
    - *Signals:* jailbreak score, exfil score, policy violations → Observable in dashboards.
- **RBAC/SSO**
    - OIDC/SAML for SSO; roles: *Analyst, IR Lead, Admin, Read-only*. All high-impact actions require role + MFA + policy approval. **[13]**
- **NIST AI RMF mapping & Release Gates**
    - Each release ships with *Model Card, System Card, Risk Register.* **[10]**
    - CI/CD gate runs safety/eval suite; failure blocks deploy.
- **Compliance Mapping (ISO 27001, MITRE ATT&CK)**
    - Policies and reports reference specific controls (e.g., ISO A.12.6) and ATT&CK tactics used/detected. **[27] [18]**

Operate it: treat the Control Plane as the source of truth. Nothing executes without a permit token from here.

4.2 Observability Plane

Purpose: make the system measurable, explainable, and debuggable.

- **Traces & Metrics**
    - Per-request spans (ingest → retrieval → inference → action).
    - Model metrics: latency, token counts, confidence, calibration error (ECE), retrieval precision. **[21]**
- **Audit (hash-chained)**
    - Every decision and policy verdict recorded with inputs hash, model version, retrieved doc hashes, and outputs. Append-only with periodic notarization. **[28]**
- **Evaluation Harness / Benchmarks**
    - Nightly OWASP LLM Top-10 tests, adversarial injection corpora, poisoning drills, replayed APT datasets. **[6]**
- **Dashboards & Alerts**
    - SLOs: p95 Stage-1/2 <2s; p95 Stage-3 <10s; jailbreak block-rate ≥99%; policy violations=0.

4.3 Data Plane

Purpose: acquire, standardize, and protect data at scale.

- **Ingestion Connectors**
    - *Sources:* Wazuh/ELK/Zeek/Suricata (logs/flows), Nessus/OpenVAS/Burp (scans), MISP/CVE/OSINT (threat intel).
    - *Transport:* Kafka topics per source; schema registry enforced. **[23]**
- **Normalization (ECS) & PII Redaction**
    - Map to Elastic Common Schema; redact or tokenize emails, IPs (as needed), user IDs. **[29]**
    - *Output:* clean ECS-like events to downstream stores.
- **Data Quality Guardrails**

    - Validate timestamps, host IDs, field presence; quarantine malformed events; emit DQ metrics. **[28]**

4.4 Core Data Stores

Purpose: the durable memory for analytics, retrieval, and graphs.

- **Data Lake (S3/MinIO)**
    - *Layout:* /tenant/year=YYYY/month=MM/day=DD/source=…/format=parquet.
    - *Security:* SSE-KMS encryption, VPC endpoints, object-lock (WORM) for audit.
    - *Retention:* policy-driven; immutable snapshots for reproducibility.
- **Vector DB / RAG**
    - *Embeddings:* bge-large or text-embedding-3-large; per-tenant namespaces; CBAC at query time.
    - *Freshness & TTL:* per-source expirations (e.g., CVE=365d, TI=90d). Annotate citations with "freshness_days". **[26] [4] [5]**
    - *Reranking & Validation:* cross-encoder rerank (top-k→top-r) and a factuality validator that rejects contradictory context.
    - *Privacy:* optional Differential Privacy embeddings; UI shows per-tenant ε budget.
    - *Adversarial Doc Scanning:* regex+heuristics+LLM rules to neutralize injected instructions in source docs.
- **Graph DB / Knowledge Graph**
    - *Schema:* nodes = {Host, User, Process, File, Domain, CVE}; edges = {Event, Auth, ConnectsTo, Spawns, Reads, Resolves}.
    - *Temporal Versions:* time-sliced graphs for "what it looked like then."
    - *API:* subgraph queries by time window, entity, or ATT&CK pattern. **[41]**

4.5 AI Core

4.5.1 Multi-Layer AI Pipeline

- **Stage-1: Rules/IOCs/Stats + SHAP**
    - Fast filters (YARA/regex/JA3/ASN), anomaly scores, thresholding; SHAP to explain classic models. **[25]**
    - *Output:* enriched events + "why" features.
- **Stage-2: Deep IDS**
    - Lightweight DNN/transformer classifiers (e.g., flow-based, log-line BERT) for semantic labeling ("credential-stuffing suspected").
    - *Escalation*: to Stage-3 when uncertainty high or impact high.
- **Stage-3: MoE LLM + RAG**
    - vLLM inference with routing (small→large). Consumes ECS event bundle + RAG citations. **[35] [24]**
    - *Self-assessment:* emits confidence∈[0,1], needs_review flags, and JSON-schema outputs.
    - *Fallbacks:* if low confidence or contradictions → return Stage-1/2 verdict with escalation note.
    - *Outputs:* classification, MITRE mapping, RCA summary, blast radius, prioritized actions.
- **Calibration & Cost Controls**
    - Temperature, top-p tuned per task; token budgets enforced; speculative decoding + KV-cache reuse.

4.5.2 LLM Reasoning Engine

- Tool-use registry (WHOIS, DNS, VT, cloud APIs) governed by the Policy Engine. **[35]**
- Deterministic JSON schemas for reports/incidents; strict validators; redaction before display.

4.5.3 GNN Anomaly Engine

- Build temporal subgraphs; score lateral movement & beaconing patterns. **[2]**
- *Explainability:* subgraph highlights + counterfactual edits ("remove edge X → non-anomalous").
- Feeds top-K suspicious subgraphs into Stage-3 context for grounded RCA.

4.6 Agents & Actions

- **Blue Team AI Agent**
  - *Plan synthesis:* ReAct (Reason+Act) generates multi-step playbooks (isolate host, disable account, block domain).
  - *Verification:* symbolic pre/post-condition checker + policy gate + AI-firewall scan.
  - *Execution:* low-impact auto; high-impact requires human approval. Full audit trail and rollback recipes.
  - *Artifacts:* executive + technical incident reports with citations, confidence, and model/system cards.
- **Red Team AI Agent (lab-only)**
  - ATT&CK-bounded planner compiles to Caldera/Metasploit/synthetic injectors. **[3]**
  - Strict allow-lists, "lab-only" prompts, and deny-lists enforced by Policy + AI Firewall.
  - Produces diverse traffic for evaluation and continual learning (no real egress).
- **Deception Systems (Honeypots/Honeytokens)**
  - Adaptive banners, services, and content tailored to attacker profile; signals feed training and ATT&CK coverage metrics.
  - Always fenced from production networks.

4.7 Feedback • Isolation • Federation

- **Human-in-the-Loop**
  - Feedback taxonomy: missed_context, hallucination, over_evasive, false_positive, useful_playbook. **[30] 31]**
  - Approval workflows for actions; feedback queues for curation; impacts: weighting, prompts, or fine-tuning buffers.
- **Secure Sandbox (TEEs)**
  - Nitro Enclaves / SEV-SNP optional for high-assurance isolation. **[32]**
  - Egress-deny default; malware detonation services; snapshot/rollback; legal "lab-only" attestations.
- **Federated Learning (opt-in)**
  - Client-side updates + secure aggregation; robust aggregation (Krum/median/trimmed-mean) and poisoning/outlier detection. **[8]**
  - No raw data leaves tenant; DP noise optional; server validates updates against hold-out evals before merge.

4.8 Cross-Cutting Capabilities

- **Self-Adaptive Control Plane (Meta-Controller)**
  - Observes novelty, calibration drift, FP spikes; adjusts AI-firewall strictness, model routing, sandbox isolation.
  - Starts heuristic; can graduate to safe RL with human approval for high-risk changes.
- **Content Provenance & Watermarking**
  - C2PA-style signatures on ingested docs; watermark generated content; retrieval refuses unsigned/unknown (configurable). **[45]**
- **Secrets & Keys**
  - Vault for API keys; short-lived tokens; per-tenant KMS keys; audit access.
- **Disaster Recovery**
  - Lake snapshots, vector backups, graph dumps; restore runbooks exercised quarterly.

4.9 Data Contracts & Key APIs

- **Event (ECS-like)**

```
{
  "ts": "2025-08-16T12:52:14Z",
  "sensor": "suricata",
  "src_ip": "10.0.3.4",
  "dst_ip": "203.0.113.7",
  "dst_port": 443,
  "proto": "TCP",
  "sig_id": "ET-C2-123",
  "message": "Suspected C2",
  "labels": ["ioc_hit"],
  "pii_fields": ["email_hash"],
  "raw_b64": "…"
}
```

- **LLM Decision Record (auditable)**

```
{
  "model": "moe-2025.08",
  "inputs_hash": "sha256:…",
  "retrieval": [
    {"doc_id": "cve-2024-xxxx", "freshness_days": 2, "prov": "signed"}
  ],
  "classification": "probable_c2",
  "confidence": 0.72,
  "mitre": ["TA0011"],
  "rca": "beacons every 60s; JA3 match",
  "actions": ["isolate", "block_domain"],
  "xai": {"stage1_shap_ref": "shap://…", "gnn_subgraph_id": "g-42"},
  "safety": {"jailbreak_checks": ["ok"], "pii_scan": "ok"},
  "timestamp": "2025-08-16T12:52:22Z"
}
```

- **RAG Query Envelope**

```
{
  "query": "suspicious outbound TLS with JA3=… map to MITRE and suggest steps",
  "context_requirements": ["MITRE", "CVE", "org_playbooks"],
  "tenant_id": "acme"
```

```
}
```

- **Policy Document (sketch)**

```
version: 1
tenant: acme
allow_tools:
  - whois
  - vt_lookup
deny_actions:
  - exploit_generation: ["prod", "internet"]
redteam:
  environment: "lab-only"
  allow_techniques: ["T1071", "T1059"]
approvals:
  isolate_host: role:IR-Lead
```

4.10 SLIs/SLOs, Failure Modes & Safeguards

- **SLIs/SLOs**
  - p95 latency: Stage-1/2 <2s; Stage-3 <10s.
  - Jailbreak block-rate ≥99% (nightly suite). **[6]**
  - Retrieval factuality pass-rate ≥95%.
  - 100% of high-impact actions require human approval.
  - 0 policy violations/month.
- **Common Failure Modes & Mitigations**
  - *Hallucinated remediation:* require needs_review or low confidence → enforce human approval; provide counterfactual "why."
  - *RAG poisoning:* provenance checks, quarantine untrusted docs, adversarial scan; rollback with retrieval snapshots.
  - *Prompt injection:* AI firewall pre/post filters; indirect-injection detectors on retrieved context.
  - *Model drift/cost spikes:* meta-controller tightens filters, routes more to small models; token budgets hard-enforced.
  - *Graph blow-up:* temporal windowing, node sampling, top-K subgraph extraction.

How components talk (quick flow recap)

1. **Data Plane** ingests & normalizes → **Data Lake** (durable), **Vector DB** (RAG), **Graph DB** (relations).
2. **AI Core** pulls: Stage-1/2 score → Stage-3 LLM reasons with RAG + **GNN** subgraphs → emits incident JSON + actions.
3. **Control Plane** gates actions via **Policy** + **AI Firewall**; all decisions are **audited**.
4. **Agents:** Blue executes (within policy), Red simulates (lab-only), Deception gathers signals.
5. **Feedback/Federation:** HITL labels fine-tune models; optional FL aggregates updates; **Observability** feeds the **Meta-controller**.

5 Data Flow Diagram Description

5.1 Data Entry and Ingestion

The data flow begins with the ingestion layer. Multiple sources contribute raw security data:

- **Log Sources:** Wazuh, ELK, Zeek, and Suricata provide system, network, and application logs.

- **Threat Intelligence Feeds:** MISP, CVE repositories, and OSINT crawlers feed structured knowledge about vulnerabilities and indicators of compromise (IOCs). **[34]**
- **Vulnerability Scanners:** Tools such as Nessus, OpenVAS, and Burp Suite contribute results from active scanning activities. **[23]**

All incoming data passes through a **Normalization & Sanitization stage** where it is mapped to the Elastic Common Schema (ECS) and processed for **PII redaction** to ensure compliance and privacy protection. **[29]**

5.2 Storage and Core Processing

After normalization, data flows into secure storage components:

- **Data Lake (S3 + Encryption):** Provides long-term, versioned, and provenance-tracked storage. Immutable backups ensure forensic integrity. **[28]**
- **Vector Database / RAG System:** Embeds ingested text and metadata into vector space for semantic retrieval. Features include context filters, re-ranking mechanisms, and TTL for freshness. **[26] [4]**
- **Graph Database / Knowledge Graph:** Transforms events into graph structures where nodes represent hosts, users, or processes, and edges represent relationships or activities. Subgraph versions enable temporal analysis of attacks. **[41]**

5.3 AI Processing and Analysis

Data then flows through the multi-layer AI pipeline:

- **Stage-1 Rules/ML + SHAP:** Initial detection using classical IDS rules, supervised ML models, and interpretable SHAP-based explanations. **[25]**
- **Stage-2 Deep Learning IDS:** Neural models process temporal and behavioral features to detect complex attacks.
- **LLM Reasoning Engine:** A Mixture-of-Experts LLM, optimized with vLLM routing and RAG augmentation, synthesizes contextual explanations, maps alerts to MITRE ATT&CK, and generates human-readable analysis. **[35] [24]**
- **Graph Neural Networks (GNNs):** Parallel anomaly detection on event graphs identifies lateral movement and command-and-control patterns, feeding ranked suspicious subgraphs back into the LLM layer. **[2]**

5.4 Decision and Action Layer

Outputs from the AI flow into specialized agents:

- **Blue Team AI Agent:** Conducts Incident Response (IR), Root Cause Analysis (RCA), forensic investigations, and automated reporting.
- **Red Team AI Agent:** Operates in controlled sandbox environments, simulating adversary tactics and generating adversarial test cases for system hardening. **[3]**
- **Deception Systems:** Adaptive honeypots and traps inject new signals back into the pipeline to confuse attackers and enrich threat intelligence.

5.5 Governance and Feedback

At this stage, **governance and human validation** ensure safe and compliant actions:

- **Control Plane:** Intercepts all decisions through policy enforcement, AI firewall checks, zero-trust gatekeeping, and NIST AI RMF-based compliance gates. **[7]**
- **Human-in-the-Loop Feedback:** Analysts tag outputs, re-rate risks, and provide continuous supervision, enabling iterative model fine-tuning.
- **Secure Sandbox (TEEs):** All active response actions are executed in isolated trusted environments with egress-deny, preventing accidental propagation of threats. **[6]**

5.6 Learning and Adaptation

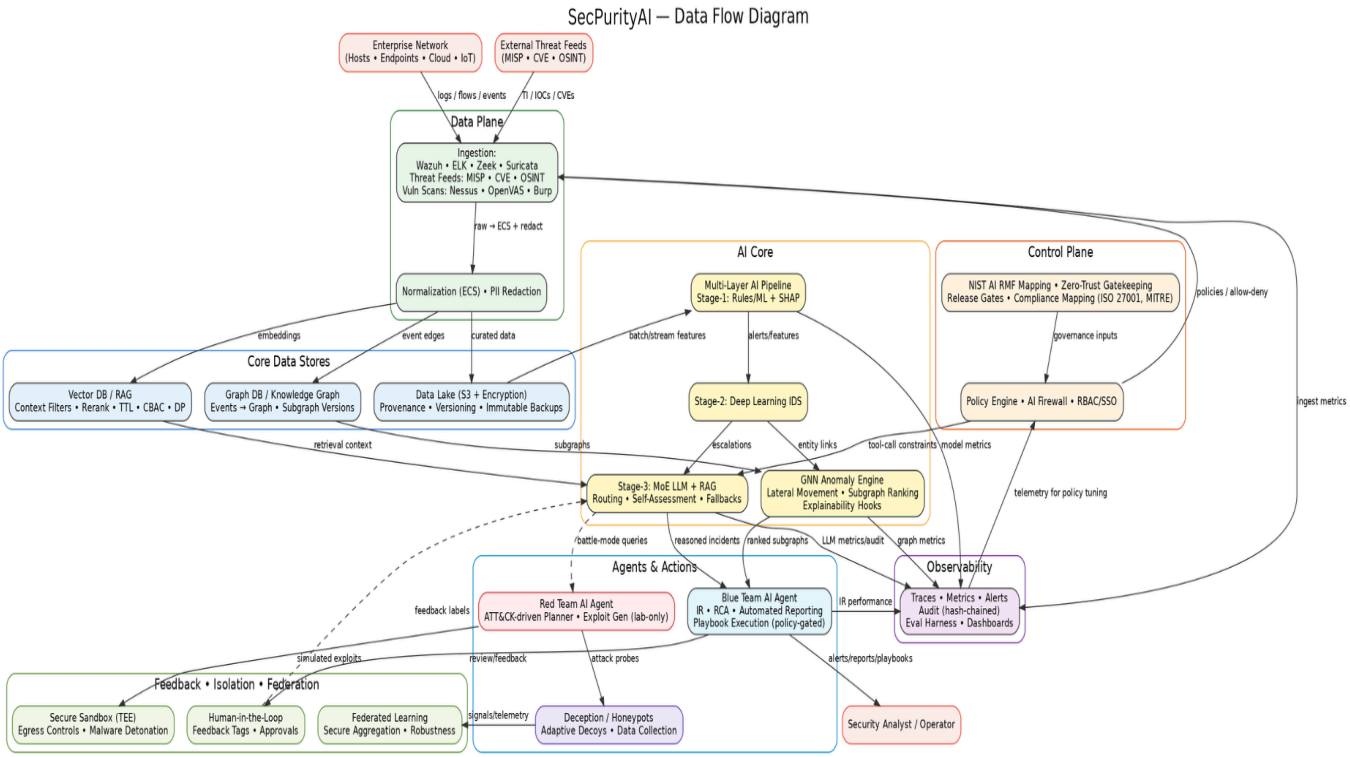
The system incorporates self-improvement loops:

- **Continuous Model Tuning:** Feedback from human analysts and observability is integrated into retraining buffers.
- **Federated Learning (Optional):** Anonymized, differentially private model updates are aggregated across organizations to improve collective defense without exposing raw data.

5.7 Observability and Audit Trail

Throughout the pipeline, all actions and data flows are logged in parallel into the observability layer:

- **Traces & Metrics:** Track latency, throughput, and detection accuracy. **[21]**
- **Hash-Chained Audit Logs:** Guarantee integrity of security events and analyst actions. **[28]**
- **Evaluation Harness & Benchmarking:** Automated test suites validate system performance nightly against adversarial cases.
- **Real-Time Dashboards:** Provide visibility for security teams and compliance officers.



6 Technology Stack & Tools

6.1 Programming Languages & Runtime

- **Python 3.11+** — primary backend, ML/LLM/GNN ecosystem, rich async (FastAPI), mature tooling.
- **TypeScript (Node 20+)** — frontend build tooling and any serverless glue (optional).
- **Bash/Terraform** — infra automation.
- **Why:** best libraries for data, ML, security tooling; fast prototyping with production viability.

Alternatives: Go (high-throughput agents, collectors), Rust (high-safety network services).

Fit: Python for AI core & APIs; TS/React for UI.

6.2 Data Plane & Storage

Event Ingestion & Streaming

- **Kafka** (Confluent Platform or Apache Kafka) + **Schema Registry[23]**
    - **Why:** high-volume log/flow ingestion; replay; back-pressure handling.
    - **Usage:** topics per source (zeek, suricata, nessus, etc.); Avro/Protobuf schemas versioned.
- **Alternatives:** Redpanda (simpler ops), NATS JetStream (lightweight), Kinesis (managed).

Hot Search / SIEM

- **OpenSearch** (or **Elasticsearch** OSS) **[33]**
    - **Why:** fast indexed search on ECS-normalized events; aggregations; Kibana-compatible dashboards (OpenSearch Dashboards).
- **Alternatives:** ClickHouse (ultra-fast analytics), Splunk (licensed).

Data Lake (durable)

- **S3/MinIO** (Parquet + Hive partitioning) **[28]**
    - **Why:** cheap durable storage, versioning, object-lock/WORM for audit.
- **Format/Tools:** Parquet, Delta/Apache Iceberg (if ACID tables needed).
- **Alternatives:** GCS/Azure Blob (cloud-native).

Vector Database (RAG)

- **Milvus** or **Qdrant[26]**
    - **Why:** open-source, performant ANN (HNSW/IVF), per-tenant namespaces; good Python SDKs.
- **Alternatives:** Weaviate, Elastic KNN (co-located), Pinecone (managed SaaS).

Graph Store / Knowledge Graph

- **Neo4j** or **TigerGraph** (community) **[41]**
    - **Why:** rich graph queries (Cypher), temporal patterns; integrates well with Python.
- **Alternatives:** JanusGraph (Cassandra backend), AWS Neptune (managed).

Metadata & Provenance

- **PostgreSQL** for system metadata, model registry pointers, provenance indices. **[36]**
- **Harbor** (images), **MLflow** (models, metrics), **DVC** or **LakeFS** (data versioning).

6.3 AI/ML Core

Model Serving & Orchestration

- **vLLM** (LLM inference server) + **FastAPI** gateway
  - **Why:** paged attention, KV cache reuse, tensor/TPU/GPU support; easy to route small→large models.
- **Ray** or **Celery** for distributed jobs (batch scoring, training).

LLMs

- **Base models (local):** Llama 3.x, Mistral, Mixtral (quantized INT8/FP8/4-bit for dev).
- **Task models:** lightweight instruction-tuned (e.g., Mistral-Instruct) for Stage-2/triage.
- **Hosted (optional):** OpenAI/Anthropic for comparison and evals (policy-gated).
- **Reasoning:** ReAct prompting; JSON schema outputs with Pydantic validation.

Embeddings

- **Sentence Transformers** (e.g., bge-large, e5-large) or OpenAI text-embedding-3-large (hosted).
- **DP option:** add calibrated noise for DP embeddings (tenant opt-in).

RAG Pipeline

- **FAISS** (local build blocks) + Milvus/Qdrant backends
- **Cross-encoder reranker:** cross-encoder/ms-marco-* or equivalent.
- **Factuality checker:** natural-language inference model; drop contradictory context.
- **Adversarial doc scanner:** heuristic+LLM rules for indirect prompt injection. **[24] [26]**

GNN (Graph Neural Networks)

- **PyTorch + PyTorch Geometric (PyG)** or **DGL**
  - **Tasks:** temporal subgraph classification (lateral movement, C2), node/edge anomaly scoring.
  - **Explainability:** GNNExplainer, Integrated Gradients, counterfactual edit search.

Classic ML & Explainability

- **scikit-learn / XGBoost** for Stage-1/2 components.
- **SHAP / Captum / Alibi** for explanations on tabular/log features. **[25]**

Causal Inference

- **DoWhy** + **Causal-learn** (+ optionally **EconML**)
  - **Use:** causal timelines, counterfactuals, impact estimation of remediations.

RL / Agent Simulation (optional)

- **PettingZoo / Gymnasium** for multi-agent testbeds (Red vs Blue policies).

- **Stable-Baselines3** for quick RL baselines.

6.4 Control Plane, Safety & Compliance

Policy & Governance

- **Open Policy Agent (OPA/Rego)** for allow/deny and conditional permits.
- **OPA bundles** stored in Git, deployed via CI/CD; policy unit tests.

AI Firewall

- **Pre-filters:** prompt sanitization; PII/secret scrubbing (custom + Presidio); jailbreak/prompt-injection heuristics.
- **Post-filters:** schema validation, PII/exfil scan, "lab-only" enforcement, deny-lists.
- **Regex + AST + small classifiers** (fast) before hitting large LLMs.

Identity & Access

- **Keycloak** or **Auth0** for SSO/OIDC/SAML.
- **RBAC** roles: Analyst, IR Lead, Admin, Read-only; **MFA** on high-risk actions.

Compliance Tooling

- **Model/System Cards** via templated Markdown + JSON metadata.
- **Change management:** GitOps; signed releases; artifact attestation (SLSA level targets).

6.5 Simulation, Deception & Isolation

Red/Blue Battle Mode

- **CALDERA** (MITRE), **Metasploit** (lab only), **Atomic Red Team** for TTP replay.
- **Traffic generation:** tcpreplay, custom Zeek scripts, synthetic log injectors.

Deception/Honeypots

- **Cowrie**, **OpenCanary**; banners/content morphing via LLM (policy-gated, no real egress).
- **Honeytokens** (Canarytokens) for lateral movement detection.

Isolation & TEEs

- **Docker + Kubernetes (k3s for dev / managed k8s in prod)** with **NetworkPolicies**, **AppArmor/SELinux**, **egress-deny**.
- **AWS Nitro Enclaves** or **AMD SEV-SNP** (optional high-assurance mode).
- **Firecracker** microVMs for malware detonation.

6.6 Observability, Audit & Evaluations

Telemetry

- **OpenTelemetry** (traces/metrics/logs) → **Prometheus** + **Grafana**.
- **Loki** (logs) integrated with OpenSearch. **[21] [39] [40]**

Audit

- **Hash-chained logs** (Merkle) with periodic notarization (e.g., time-stamping service).
- **Immutable object-lock** snapshots in S3 for reports and decision records.

Evaluation Harness

- **Nightly suites:** OWASP LLM Top-10 red-team tests; indirect injection corpora; poisoning drills.
- **Benchmarks:** internal APT replays; public datasets (where allowed).
- **Reporting:** HTML/PDF auto-reports; gating thresholds enforce in CI. **[38]**

6.7 Backend APIs & Services

API Frameworks

- **FastAPI** (Python) for REST/JSON + WebSockets.
- **gRPC** (optional) for high-throughput internal RPC.

Background Work

- **Celery + Redis/RabbitMQ** for jobs (scoring, batch feature generation, report builds).
- **Ray** for distributed training/inference bursts.

Packaging & Deployment

- **Docker** images; **Helm** charts; **ArgoCD** (GitOps).
- **Terraform** for cloud infra; **Ansible** for host hardening.

6.8 Frontend / Analyst Experience

Web UI

- **React + TypeScript**, **Vite** bundler.
- **UI kits:** shadcn/ui, Radix UI; data viz with **ECharts** or **Recharts**; **D3** for graph viz.
- **Auth:** OIDC flow with token refresh; role-based menus.

Views

- **Incidents/Reports:** model/system cards, citations, confidence, MITRE mapping.
- **RCA Graphs:** interactive subgraph explorer (node/edge explanations).
- **Battle Mode:** live red vs blue timeline, scoring, controls (policy-gated).
- **Governance:** policy editor (Rego), release gates, safety dashboards.

6.9 MLOps & DataOps

- **MLflow** for model registry/metrics/artifacts.

- **DVC/LakeFS** for dataset/version lineage.
- **Great Expectations** for data quality checks on ingestion.
- **CI/CD:** GitHub Actions/GitLab CI; runners with GPU labels; policy and eval gates.
- **Rollouts:** progressive (canary/blue-green); model shadow testing before switch-over.

6.10 Security Hardening & Secrets

- **Vault** (HashiCorp) for secrets; short-lived tokens; KMS per tenant.
- **SBOM** (Syft/Grype); image signing (cosign, Sigstore).
- **Network:** mutual TLS inside cluster; zero-trust between services; mTLS cert rotation.
- **Host:** CIS benchmarks, kernel lockdown features, AppArmor profiles. **[38]**

6.11 Local Dev vs Production Profiles

- **Local (Mac M4 Pro):**
  - Milvus/Qdrant in Docker; MinIO; Neo4j community; vLLM with small quant models (4-bit).
  - Ray on single node; k3s for k8s-like dev; FastAPI with auto-reload.
- **Prod/Staging:**
  - Managed k8s (EKS/GKE/AKS); GPU pools (A10/A100/H100) for LLM/GNN bursts.
  - Auto-scaling vector/graph clusters; S3 lifecycle policies; Cloud KMS + IAM boundaries.

6.12 Recommended Versions (starting points)

- Python **3.11**; FastAPI **0.112+**; vLLM **0.5+**; PyTorch **2.3+**; PyG **2.4+**
- Milvus **2.4+** or Qdrant **1.8+**; Neo4j **5.x**; OpenSearch **2.x**
- Kafka **3.x**; Ray **2.9+**; MLflow **2.13+**; Grafana **10+**; Prometheus **2.49+**

  (Exact versions can be pinned in a versions.lock.md and Helm values.)

7 Governance & Safety Framework

7.1 Alignment with Standards

- **NIST AI RMF (Risk Management Framework):**
  - **Map AI lifecycle risks:** Identify, Measure, Manage, Monitor.
  - **Implementation:** Traceability matrix mapping each SecPurityAI subsystem to RMF categories.
  - Example: RAG subsystem → "Explainability & Interpretability," Red Team Agent → "Misuse Prevention." **[7]**
- **ISO/IEC 27001:**
  - Policies and controls integrated into the **Control Plane**.
  - Example: Encryption at rest (S3/Vector DB), RBAC/SSO (identity domain), logging & monitoring (A.12.4). **[27]**
- **MITRE ATT&CK / D3FEND Mapping:**
  - Each anomaly detection and simulation mapped to ATT&CK tactics/techniques.
  - Defensive controls (Blue Agent, deception) mapped to D3FEND countermeasures.

7.2 AI Firewall & Policy Enforcement

- **Policy Engine:**
  - OPA/Rego rules define what the AI can/cannot do.
  - Example: deny commands with outbound network traffic in sandbox; redact secrets before LLM input. **[6]**
- **AI Firewall Layers:**
  - **Pre-filter:** Sanitization of input (strip secrets, detect jailbreak attempts).
  - **Core:** Guardrails on agent actions (e.g., Blue Agent can't auto-patch prod).
  - **Post-filter:** Validate LLM output (JSON schema, block unsafe responses). **[19]**
- **Governance Hooks:**
  - Each policy change logged, peer-reviewed, and signed off before release.
  - "Release gates" stop deployment if safety tests fail.

7.3 Audit & Transparency

- **Audit Logs:**
  - Hash-chained (Merkle tree) event logs for immutability.
  - Stored in WORM (Write Once Read Many) storage (S3 Object Lock). **[28]**
- **Model/Decision Cards:**
  - Each AI output is logged with: input, reasoning, model version, confidence, explanation, compliance mapping.
  - Analysts can see *why* a decision was made (e.g., SHAP scores, causal graph).
- **Explainability:**
  - GNN Explainer, SHAP, counterfactuals, causal inference outputs stored with the event.
  - Enables compliance officers to validate models beyond black-box behavior. **[28]**

7.4 Human-in-the-Loop Controls

- **Feedback Tags:** Analysts can flag outputs with granular reasons: "missed context," "false positive," "unsafe."
- **Risk Overrides:** For sensitive actions (e.g., automated response), require dual approval.
- **Continuous Learning:** Feedback loop informs federated retraining (aggregated across orgs with DP).

7.5 Release Gates & Continuous Validation

- **Pre-deployment checks:**
  - Models undergo evaluation harness tests: OWASP LLM Top-10 adversarial inputs, indirect prompt injection tests, red-team exploit sets. **[6]**
  - If pass rate < threshold → deployment blocked.
- **Continuous evaluation:**
  - Nightly replays of APT datasets, adversarial prompt corpus.
  - Reports auto-generated; deviations trigger alerts.
- **Safe rollback:**
  - Canary deploys; if false positives > baseline, auto-revert to prior model.

7.6 Ethical & Safety Considerations

- **Misuse Prevention:**
  - Red Team Agent restricted to sandbox only; all generated exploits stay within controlled labs.
  - Output watermarking (to identify AI-generated code/logs).
- **Privacy:**
  - PII redaction at ingestion; optional DP embeddings for RAG.
  - Secure enclaves for sensitive data.
- **Fairness & Bias:**
  - Test datasets cover diverse environments (enterprise, SME, OT/ICS).
  - Bias metrics tracked (e.g., false positive/negative disparity across data sources).

7.7 Governance Dashboard (UI/UX)

- **Policy Editor:** GUI to manage OPA rules.
- **Audit Viewer:** Drill down into past AI decisions with context/explanation.
- **Compliance Mapper:** Visual mapping of controls to NIST/ISO/MITRE frameworks.
- **Release Gate Status:** Show which models passed/failed latest test suite. **[18]**

8 Implementation Roadmap & Phases

8.1 Phase 0 – Foundations

Goal: Lay the groundwork for ingestion, policies, and baseline ML.

- **Tasks:**
  - Set up ingestion (logs from Zeek/Suricata, CVE/MISP feeds).
  - Normalize into **ECS schema**.
  - Basic **RBAC/SSO**, **policy engine**, and **audit logging**.
  - Train/test a **Stage-1 ML IDS (Random Forest/SVM/CNN)** with SHAP for explainability.
  - Minimal React dashboard for alerts.

Deliverable:

Alerts flow end-to-end: log → detection → explainable alert in UI → audit log.

8.2 Phase 1 – RAG Brain & Policy Enforcement

Goal: Enable reasoning and retrieval with guardrails.

- **Tasks:**
  - Stand up **vector DB** with namespaces & TTL.
  - Add **Context-Based Access Control (CBAC)**.
  - Implement **AI Firewall (pre/post filters)**.
  - Integrate **LLM reasoning engine (small open-source LLM + RAG)**.

    - Logging of **Model/Decision Cards** with confidence.

Deliverable:

Analyst queries flow to RAG-enhanced LLM, safe responses shown with provenance.

8.3 Phase 2 – Red vs Blue MVP

Goal: Controlled adversarial simulation & detection loop.

- **Tasks:**
    - Build **Red Team Agent** restricted to lab-only sandbox (Metasploit/Caldera).
    - Build **Blue Team Agent** to triage and explain attacks.
    - Link with MITRE ATT&CK coverage mapping.
    - Add scoring metrics (MTTD, FP/FN, evasions).
    - Governance release gate: safety tests must pass before deployment.

Deliverable:

A full "battle mode" in controlled lab, with attack simulation → detection → Blue Agent response.

8.4 Phase 3 – Graph Intelligence

Goal: Detect subtle, lateral-movement attacks.

- **Tasks:**
    - Build **Graph DB** (events → graph with subgraph versions).
    - Implement **GNN anomaly detector** (rank subgraphs).
    - Integrate GNN alerts into LLM RCA (root cause analysis).
    - Add causal inference layer (what likely caused what, blast radius).

Deliverable:

Graph anomalies detected, correlated with LLM explanations & causal timelines.

8.5 Phase 4 – Privacy & Federation

Goal: Make the system safe for multi-tenant research.

- **Tasks:**
    - Add **Differential Privacy embeddings** (tenant opt-in).
    - Build **privacy budget tracker** in dashboard.
    - Enable **Federated Learning** with secure aggregation + robust aggregation (Krum/median).
    - Ensure poisoning/outlier detection on updates.

Deliverable:

Collaborative learning across tenants with privacy guarantees.

8.6 Phase 5 – Deception & High Assurance

Goal: Adaptive attacker profiling and stronger isolation.

- **Tasks:**
  - Build **Deception Systems (honeypots, adaptive traps)**.
  - Integrate honeypot telemetry into training.
  - Enable **TEE sandbox** (Nitro Enclaves/SEV-SNP).
  - Expand adversarial doc scanner for RAG injection defense.

Deliverable:

Deception system generates adaptive attack traces, isolated in TEE-controlled lab.

8.7 Phase 6 – Hardening & Research Publication

Goal: Stabilize for release + publish results.

- **Tasks:**
  - Automate **Safety-as-Code** testing (OWASP LLM Top-10, adversarial prompts).
  - Benchmark vs baseline SIEM/IDS solutions.
  - Publish **System Cards, Transparency Reports, Benchmarks**.
  - Prepare research paper(s) on hybrid LLM+GNN detection, AI firewall effectiveness, DP trade-offs.

Deliverable:

A hardened, research-grade SecPurityAI with reproducible results and publishable benchmarks.

9 Evaluation & Benchmarking Plan — SecPurityAI

9.1 Core Evaluation Dimensions

SecPurityAI must be evaluated not only for **detection accuracy**, but also for **explainability, resilience, safety, and efficiency**.

We group the benchmarks into six dimensions:

1. **Detection Effectiveness**
   - Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR).
   - Detection rates (True Positive Rate, False Positive Rate, False Negative Rate).
   - Benchmark datasets: **CIC-IDS2017**, **DARPA Intrusion Detection Evaluation**, **CTU-13 Botnet Dataset**, plus enterprise SOC log samples.
2. **Reasoning & Explainability**
   - % of alerts with valid provenance citations (target ≥ 95%).
   - SHAP alignment score: do analysts agree with SHAP attributions ≥ 80%?
   - Counterfactual reasoning validation (e.g., “if server X was patched, would attack Y succeed?”).
3. **Safety & Robustness**
   - OWASP LLM Top-10 jailbreak test suite pass rate (≥ 99%).

    - Prompt-injection red-teaming success rate (< 1%).
    - RAG poisoning detection rate on seeded adversarial documents (> 90%).
4. **Privacy & Compliance**
    - Epsilon (ε) privacy budget tracking for DP-enabled embeddings.
    - % ingested docs with valid cryptographic provenance signatures (≥ 95%).
    - GDPR/ISO27001 compliance audits simulated via test harness.
5. **System Performance & Scalability**
    - p95 response latency: < 2s for Stage-1/2 alerts, < 10s for escalated Stage-3 reasoning.
    - Cost efficiency (tokens per incident, GPU utilization).
    - Horizontal scaling tests with 10x data ingestion (elasticity of pipelines).
6. **Human-in-the-Loop Efficiency**
    - Analyst workload reduction (alerts triaged per hour vs. baseline SOC).
    - Trust metrics: % of analyst decisions aligned with SecPurityAI recommendations.
    - Active learning uplift: % improvement in model calibration after feedback loops.

9.2 Benchmarking Methodology

a) Synthetic & Replay Testing

- Replay real attack traces (e.g., WannaCry, SolarWinds, APT29 lateral movement) into the pipeline.
- Use **Caldera** and **Metasploit** for automated adversary emulation.
- Measure detection coverage against MITRE ATT&CK TTPs.

b) Adversarial Evaluation

- Seed adversarial prompts into RAG docs (indirect injections, poisoned CVEs).
- Test LLM jailbreak resistance with known corpora (e.g., AdvBench, PromptInject).
- Evaluate model inversion risk on embeddings with simulated attacks.

c) Human-AI Interaction Studies

- Conduct **analyst-in-the-loop trials** with simulated SOC teams.
- Metrics: alert fatigue reduction, decision confidence, RCA accuracy, time-to-resolution.

d) Comparative Baselines

- Compare against:
    - **Traditional IDS/IPS** (Snort, Suricata).
    - **ML-based IDS** (kits like Kitsune, CICFlowMeter-based models).
    - **Commercial SOC tools** (Splunk ES, Elastic Security) for detection and triage.

9.3 Continuous Evaluation Pipeline

SecPurityAI integrates *evaluation-as-code*:

- **CI/CD Integration:** every release runs a fixed benchmark suite.
- **Nightly Regression Testing:** replay of recent incidents + synthetic red team attacks.
- **KPIs Monitored in Real-Time:** dashboard for MTTD, false positive ratio, jailbreak block rate.
- **Version-Pinned Benchmarks:** ensures reproducibility for research publication.

9.4 Research & Publication Value

By combining **standard benchmarks (CIC-IDS, DARPA, MITRE ATT&CK)** with **novel evaluation methods (causal inference, adaptive honeypots, RAG poisoning tests)**, SecPurityAI will produce *research-grade results*.

This makes the platform publishable in venues like **IEEE S&P, NDSS, CCS, or Usenix Security**.

10 Use Cases & Scenarios

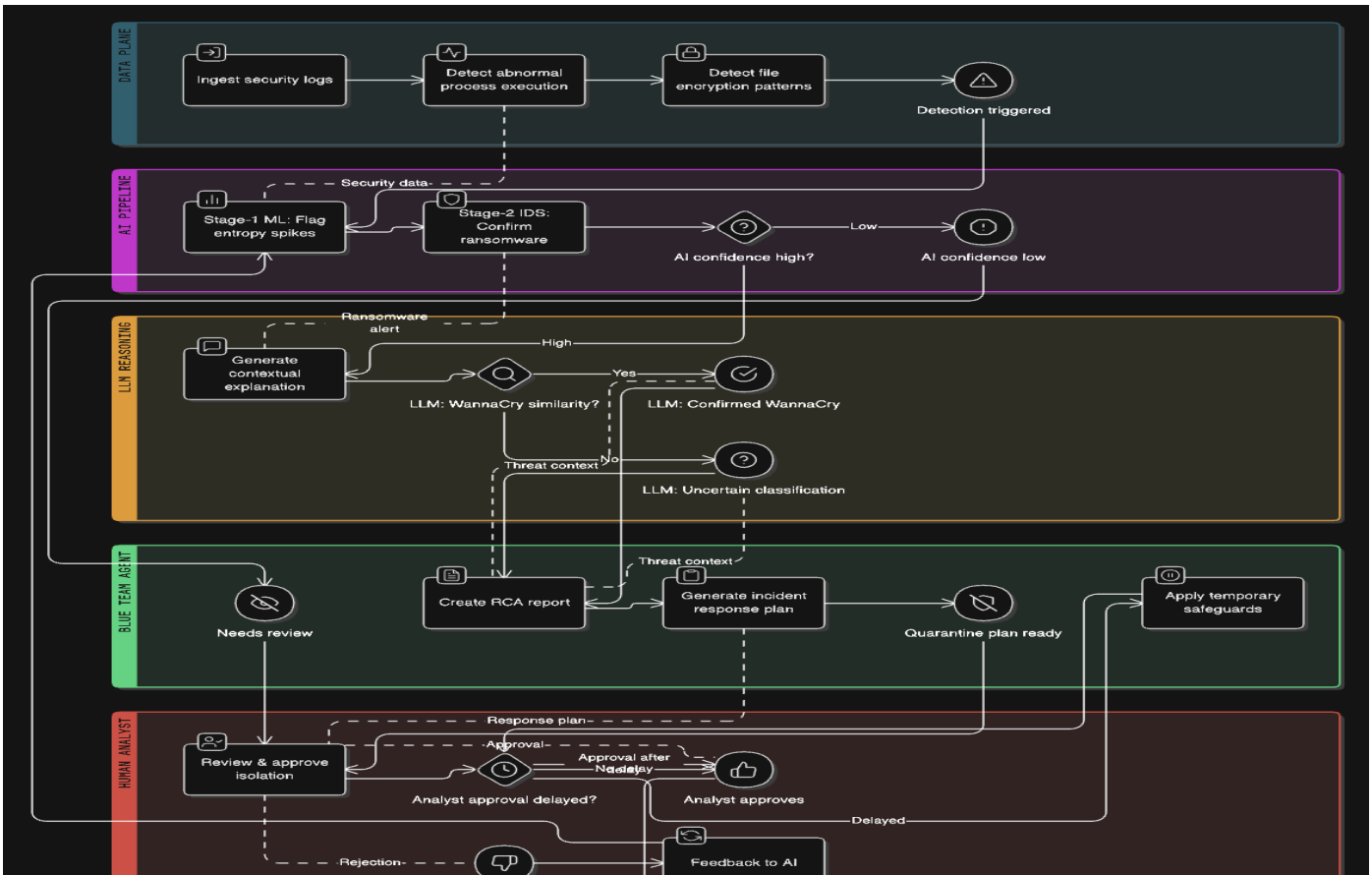
SecPurityAI is designed not just as a research prototype, but as a **multi-layer defense and reasoning platform**. Below are example **real-world scenarios** where it would shine, with step-by-step descriptions.

10.1 Ransomware Outbreak Detection & Response

Scenario: A finance company sees sudden spikes in file encryption events on their file servers.

Flow:

- **Data Plane**: Sysmon + Suricata logs ingested; abnormal process execution detected.
- **AI Pipeline**: Stage-1 ML flags suspicious entropy spikes in file writes. Stage-2 IDS confirms similarity to known ransomware.
- **LLM Reasoning**: Explains "Process X resembles WannaCry family, encryption rate exceeds baseline."
- **BlueTeam Agent**: Generates an RCA + immediate action plan (quarantine affected servers, disable SMBv1).
- **Human-in-loop**: Analyst approves isolating compromised systems.
- **Outcome**: Attack contained in <5 minutes, RCA stored for compliance.

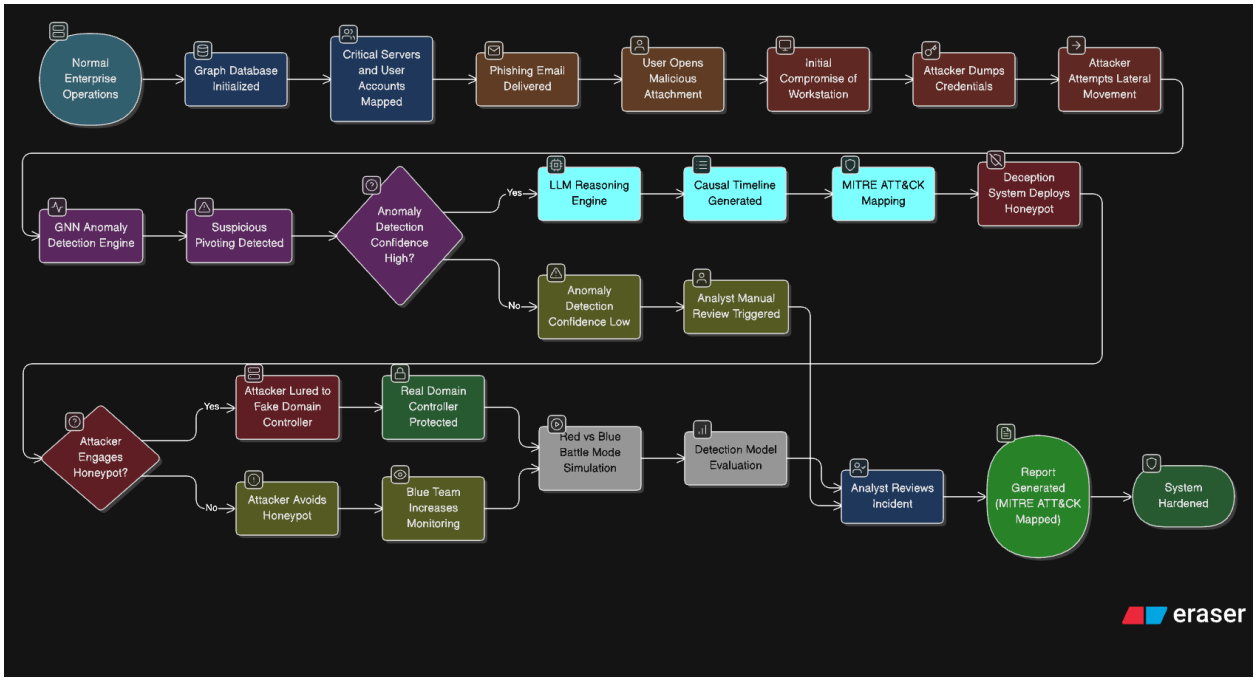


10.2 APT Lateral Movement (Advanced Persistent Threat)

Scenario: An attacker compromises one user's workstation and moves laterally through the network.

Flow:

- **Graph DB**: Hosts, user accounts, and processes represented as a graph.
- **GNN Anomaly Detection**: Identifies suspicious pivoting behavior from one host to multiple admins.
- **LLM Reasoning Engine**: Builds a causal timeline: "Initial compromise via phishing → credential dump → PsExec lateral move."
- **Deception System**: Deploys adaptive honeypot (fake DC) to trap attacker.
- **Red vs Blue Battle Mode**: Replays the incident for training.
- **Outcome**: Early detection prevents domain-wide compromise, report mapped to MITRE ATT&CK.

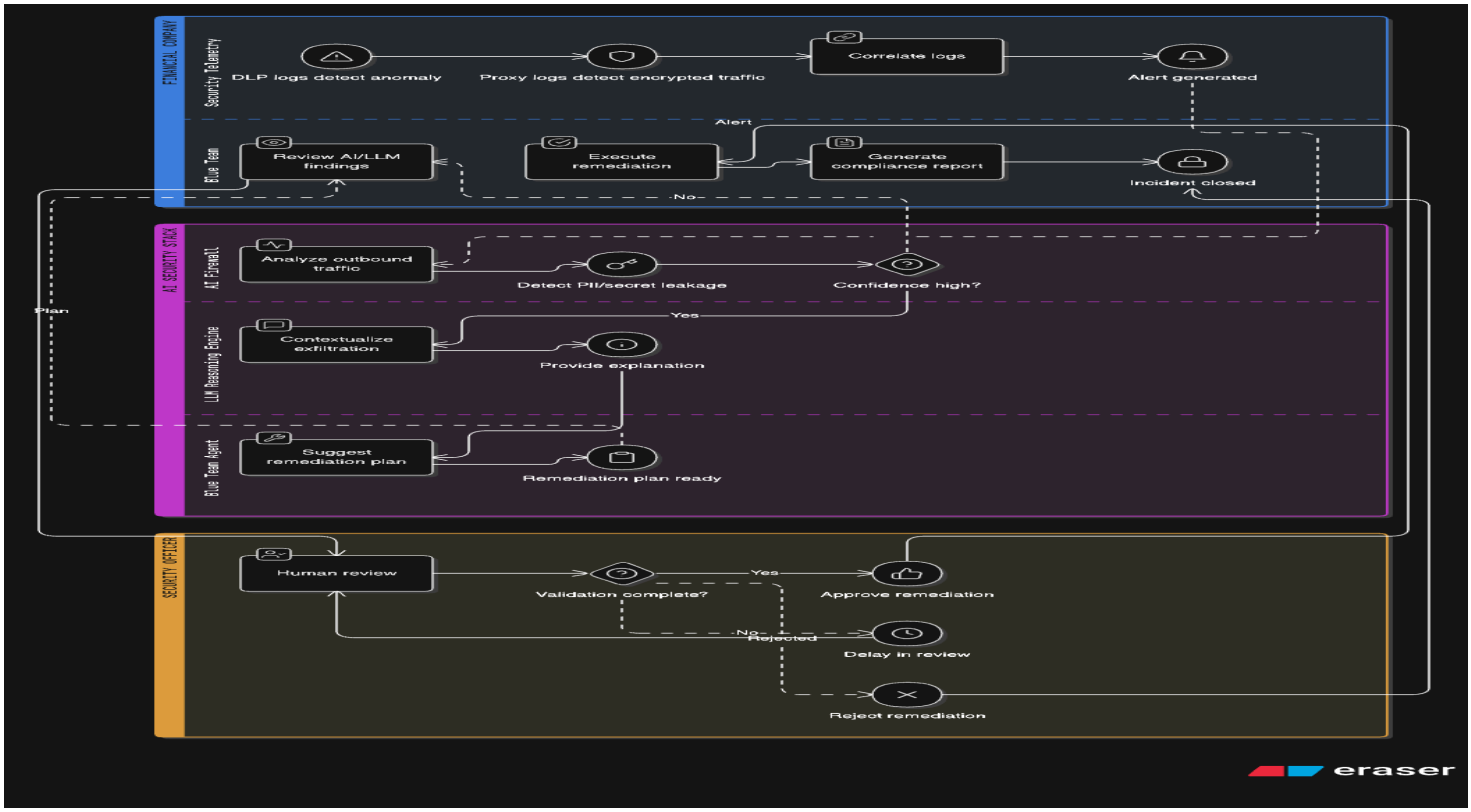


10.3 Insider Threat / Data Exfiltration

Scenario: A privileged user attempts to exfiltrate sensitive customer data.

Flow:

- **Ingestion**: DLP logs + proxy server traffic → unusual volume of encrypted traffic to personal cloud.
- **AI Firewall**: Detects possible PII/secret leakage.
- **LLM Reasoning**: "This matches insider exfiltration behavior — exfil path bypassed VPN using browser."
- **BlueTeam Agent**: Suggests blocking destination domain and rotating user credentials.
- **Human-in-Loop**: Security officer validates before action.
- **Outcome**: Prevented major regulatory breach, automated report for compliance.

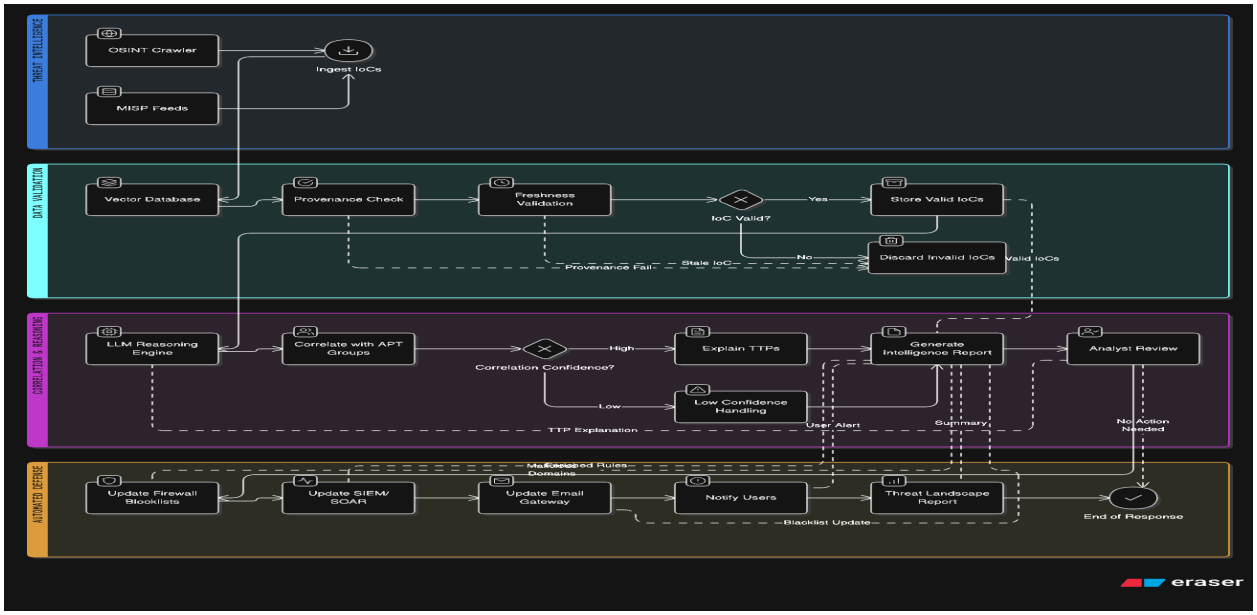


10.4 Threat Intel Fusion

Scenario: Global surge in phishing domains mimicking Office365.

Flow:

- **OSINT Crawler + MISP Feeds** ingest thousands of new IoCs.
- **Vector DB (RAG)**: Ingests domain signatures + WHOIS data with provenance checks.
- **LLM Reasoning Engine**: Correlates phishing campaigns to regional APT groups.
- **Outcome**: Actionable report to analysts; firewall updated automatically with new blocklists.



11 Future Research Directions

SecPurityAI is designed to **evolve alongside the threat landscape**. Future exploration includes:

1. **Quantum-Safe Security**
   - Integration of post-quantum cryptography (PQC) for data-at-rest & communication channels.
   - LLM reasoning about quantum-era risks.
2. **Cross-Modal Threat Detection**
   - Extend beyond logs → analyze images (screenshots), voice phishing (vishing), deepfakes.
   - Multi-modal embeddings to detect social engineering attacks.
3. **AI-Generated Malware Countermeasures**
   - Train adversarial AI models to auto-generate polymorphic malware samples.
   - Use reinforcement learning to adapt defense strategies.
4. **Collaborative Global Defense Grid**
   - Cross-enterprise **federated threat intelligence**, privacy-preserving.
   - Global "cyber weather map" for real-time attack campaigns.
5. **Explainable AI for Regulation & Trust**
   - Move beyond SHAP → counterfactual explanations, causal reasoning.
   - Policy-driven explainability tailored for SOCs, auditors, and regulators.
6. **Autonomous Cybersecurity Agents**
   - LLM-driven multi-agent systems capable of **planning & executing** IR steps with limited human oversight.
   - Governed under "safety rails" (compliance, RBAC, sandbox restrictions).

12 References

[1] M. Sajid *et al.*, "Enhancing intrusion detection: a hybrid machine and deep learning approach," *Journal of Cloud Computing*, 2024. (Hybrid IDS improves accuracy / mitigates false alarms).

[2] Z. Xu *et al.*, "Lateral Movement Detection via Time-aware Subgraph Classification on Authentication Logs," *arXiv:2411.10279*, 2024. (GNNs for lateral movement).

[3] **MITRE Caldera** — Adversary emulation platform (docs & site), MITRE, 2024–2025. (Autonomous breach-and-attack simulation/red-team).

[4] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *arXiv:2005.11401*, 2020. (RAG foundation).

[5] S. Zhao *et al.*, "Retrieval Augmented Generation (RAG) and its Applications: A Survey," *arXiv:2409.14924*, 2024. (RAG overview & challenges).

[6] **OWASP** Project, *Top 10 for LLM Applications*, v1.0–1.1, 2023–2024. (Prompt injection, insecure output handling, etc.).

[7] **NIST**, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1, 2023; *Generative AI Profile*, NIST AI 600-1, 2024. (Risk management, trustworthy AI).

[8] H. B. McMahan *et al.*, "Communication-Efficient Learning of Deep Networks from Decentralized Data," *AISTATS (PMLR)*, 2017. (Federated learning / FedAvg).

[9] M. Abadi *et al.*, "Deep Learning with Differential Privacy," *ACM CCS*, 2016. (DP training for neural nets).

[10] M. Mitchell *et al.*, "Model Cards for Model Reporting," *FAT* '19 (ACM)*, 2019. (Documenting models/decisions).

[11] **FBI Internet Crime Complaint Center (IC3)**, "Criminals Use Generative Artificial Intelligence to Facilitate Fraud," Public Service Announcement PSA241203, Dec. 3, 2024.

[12] **Mandiant**, *M-Trends 2024*, Apr. 2024, pp. 6–8 (global median dwell time: 10 days in 2023).

[13] **NIST**, *SP 800-207: Zero Trust Architecture*, Aug. 2020.

[14] **European Commission**, "AI Act enters into force," News release, Aug. 1, 2024.

[15] **EU Artificial Intelligence Act**, Article 13 (Transparency and provision of information) / Article 14 (Human oversight), consolidated reference site.

[16] **ENISA**, *ENISA Threat Landscape 2024* (annual report; trends across ransomware, availability, data threats), Sept. 2024.

[17] **CISA**, *Risk in Focus: Generative AI and the 2024 Election Cycle*, May 2024 (overview of gen-AI-enabled attack capabilities & mitigations).

[18] **MITRE ATT&CK®**, “Globally accessible knowledge base of adversary tactics and techniques,” access: Aug. 2025.

[19] **Open Policy Agent (OPA)**, “What is OPA? Policy-as-code and Rego documentation,” access: Aug. 2025.

[20] **CISA**, “Best Practices for MITRE ATT&CK® Mapping,” June 2021.

[21] OpenTelemetry, “Concepts: logs, traces, metrics,” opentelemetry.io, accessed Sept. 2, 2025.

[22] Kubernetes, “Concepts: Overview & Workloads,” kubernetes.io, accessed Sept. 2, 2025.

[23] Apache Kafka, “Documentation & Introduction,” kafka.apache.org, accessed Sept. 2, 2025.

[24] LangChain, “Retrieval-Augmented Generation (RAG) — concepts & tutorial,” accessed Sept. 2, 2025.

[25] S. M. Lundberg and S.-I. Lee, “A Unified Approach to Interpreting Model Predictions (SHAP),” NeurIPS 2017.

[26] Milvus, “Vector database documentation,” milvus.io, accessed Sept. 2, 2025.

[27] ISO/IEC 27001:2022, “Information security management systems,” iso.org, accessed Sept. 2, 2025.

[28] AWS, “Amazon S3 Object Lock — WORM storage,” accessed Sept. 2, 2025.

[29] Elastic, “Elastic Common Schema (ECS) — Reference,” accessed Sept. 2, 2025.

[30] AWS, “What is Nitro Enclaves?” accessed Sept. 2, 2025.

[31] AMD, “SEV-SNP: Strengthening VM Isolation — White Paper,” 2020.

[32] Firecracker, “Firecracker microVMs — Project site,” accessed Sept. 2, 2025.

[33] OpenSearch, “OpenSearch Documentation (incl. Dashboards),” accessed Sept. 2, 2025.

[34] MISP Project, “Documentation & Support,” misp-project.org, accessed Sept. 2, 2025.

[35] vLLM Project, “vLLM Documentation — high-throughput LLM serving,” accessed Sept. 2, 2025.

[36] MLflow, “Documentation (platform for ML lifecycle),” mlflow.org, accessed Sept. 2, 2025.

[37] lakeFS, “Documentation — data-lake version control,” accessed Sept. 2, 2025.

[38] HashiCorp, “Vault — Secrets management tutorials,” developer.hashicorp.com, accessed Sept. 2, 2025.

[39] Prometheus, “Overview — monitoring & time-series DB,” prometheus.io, accessed Sept. 2, 2025.

[40] Grafana Labs, “About Grafana — visualization & alerting,” grafana.com, accessed Sept. 2, 2025.

[41] Neo4j, “Documentation — Graph Database,” neo4j.com/docs, accessed Sept. 2, 2025.

[42] Canadian Institute for Cybersecurity, “CIC-IDS2017 dataset,” UNB, accessed Sept. 2, 2025.

[43] MIT Lincoln Laboratory, “1998/1999 DARPA Intrusion Detection Evaluation Datasets,” accessed Sept. 2, 2025.

[44] Stratosphere IPS (CTU-Prague), “CTU-13 botnet dataset (overview/links),” accessed Sept. 2, 2025.

[45] C2PA, “Content Credentials — Technical Specification,” c2pa.org, accessed Sept. 2, 2025.